سياسة · Policy

سياسة إدارة المخاطر

IT Risk Management Policy

رمز السياسة	ICTD-19P	**رقم الإصدار**	12.0
تاريخ الإصدار	5 نوفمبر 2026	**المراجعة القادمة**	5 نوفمبر 2027 (سنويًا)
الجهة المالكة	الإدارة التنفيذية للاتصالات وتقنية المعلومات	**جهة الاعتماد**	رئيس الجامعة
التصنيف	سري	**الحالة**	معتمدة

جدول المحتويات

1. الغرض
2. النطاق
3. المرجعيات النظامية والمعايير
4. السياسات
5. مصفوفة مستويات المخاطر
6. الإجراءات
7. الاستثناءات وطلبات الإعفاء
8. الإنفاذ والامتثال
9. الأدوار والمسؤوليات
10. السياسات ذات العلاقة
11. المصطلحات والتعريفات
12. تاريخ المراجعة
13. اعتماد الوثيقة

1. الغرض

تهدف هذه السياسة إلى وضع إطار لتحديد المخاطر المتعلقة بتقنية المعلومات في الجامعة وتقييمها ومعالجتها وإدارتها، لضمان أمن الأصول والخدمات الرقمية وتوافرها وسلامتها.

2. النطاق

تنطبق هذه السياسة على جميع العمليات والأنظمة والخدمات والأفراد في الإدارة التنفيذية للاتصالات وتقنية المعلومات، وعلى المخاطر التقنية الناشئة عن المشاريع والتغييرات والأطراف الخارجية.

3. المرجعيات النظامية والمعايير

تسترشد هذه السياسة بالمرجعيات التالية، وتُراجَع عند صدور أي تحديث عليها:

- الضوابط الأساسية للأمن السيبراني (ECC) الصادرة عن الهيئة الوطنية للأمن السيبراني، ولا سيما الضوابط المتعلقة بإدارة مخاطر الأمن السيبراني.
- المواصفات الدولية ISO/IEC 27001 وISO/IEC 27005 وISO 31000.
- الأنظمة والمتطلبات النظامية المحلية ذات العلاقة.

4. السياسات

4.1 تحديد المخاطر ومعالجتها

- تحدد الإدارة بشكل استباقي المخاطر المحتملة على أنظمتها وبياناتها، بما يشمل أمن البيانات والبنية التحتية للشبكة وتوافر الخدمات.
- تُحلَّل المخاطر لتقييم أثرها المحتمل على عمليات الجامعة، وتُنفَّذ خطط المعالجة لتقليل احتماليتها وشدتها.

4.2 مستويات المخاطر وخيارات المعالجة

- يُحدَّد مستوى الخطر بحاصل ضرب الاحتمالية في الأثر، على مقياس من 1 إلى 5 لكل منهما، وفق مصفوفة مستويات المخاطر.
- تُعالَج المخاطر بأحد الخيارات: التجنب، أو التخفيف، أو النقل، أو القبول.
- يُقبل الخطر وفق صلاحيات القبول المحددة في المصفوفة، ويجب توثيق جميع المخاطر المقبولة ومتابعتها.

4.3 المراقبة المستمرة

- تراقب الإدارة باستمرار فعالية إجراءات المعالجة، عبر التدقيق الدوري، والفحوص الأمنية، ومراقبة التهديدات الخارجية.
- تُتابع المخاطر في سجل المخاطر طوال دورة حياتها، بما يتكيف مع التهديدات الناشئة والتغيرات التقنية.

4.4 الامتثال للمعايير

- تتوافق إجراءات إدارة المخاطر مع المعايير الوطنية والدولية ذات الصلة والمتطلبات النظامية المحلية.
- تُراجَع ممارسات إدارة المخاطر دوريًا لضمان الامتثال وتحديد مجالات التحسين.

5. مصفوفة مستويات المخاطر

المستوى	الدرجة (الاحتمالية × الأثر)	المعالجة المطلوبة	صلاحية قبول الخطر	دورية المراجعة
حرج	20 – 25	معالجة فورية وإبلاغ الإدارة العليا	رئيس الجامعة	شهريًا
مرتفع	12 – 19	خطة معالجة خلال 30 يومًا	الرئيس التنفيذي للإدارة التنفيذية للاتصالات وتقنية المعلومات	شهريًا

المستوى	الدرجة (الاحتمالية × الأثر)	المعالجة المطلوبة	صلاحية قبول الخطر	دورية المراجعة
متوسط	6 – 11	خطة معالجة خلال 90 يومًا	مدير الإدارة المعنية	ربع سنويًا
منخفض	1 – 5	يجوز القبول مع المتابعة	مالك الخطر	نصف سنويًا

6. الإجراءات

6.1 تحديد المخاطر

تجري الإدارة تقييمات منتظمة للمخاطر المحتملة على أنظمتها وبياناتها، ويمكن تحديد المخاطر من مصادر متعددة، منها:

- فريق الإدارة التنفيذية للاتصالات وتقنية المعلومات.
- التقييمات الخارجية.
- تقارير الحوادث.
- سجلات الأمان.
- استطلاعات الموظفين.

6.2 تقييم المخاطر

- تُقيَّم المخاطر المحددة بتحديد أثرها (الضرر المحتمل على الجامعة) واحتمالية وقوعها، ويُحدَّد مستواها وفق مصفوفة مستويات المخاطر.

6.3 معالجة المخاطر

تُعالَج المخاطر لتقليل أثرها واحتماليتها، ومن تدابير المعالجة:

- تطبيق الضوابط الأمنية.
- تدريب الموظفين.
- حملات التوعية.
- مراقبة الأنظمة لرصد التهديدات.

6.4 قبول المخاطر

- يجوز قبول الخطر إذا كان أثره واحتماليته منخفضين، أو وفق صلاحية القبول المحددة في المصفوفة.
- يُوثَّق قرار القبول ومبرره ومدته في سجل المخاطر، ويُعاد تقييمه في موعد المراجعة.

6.5 سجل المخاطر

يتضمن سجل المخاطر كحد أدنى:

- التاريخ: تاريخ تحديد الخطر أو تعديله، ويجوز إضافة التاريخ المستهدف وتاريخ الإنجاز.
- رقم الخطر: رقم فريد يميزه.
- وصف الخطر: وصف مختصر للخطر وأسبابه وأثره.
- الضوابط الحالية: الضوابط المطبقة حاليًا.
- الاحتمالية والأثر ومستوى الخطر.
- استراتيجية المعالجة: الإجراء المطلوب لتقليل الخطر.
- مالك الخطر: الشخص المسؤول عن إدارة المعالجة والاستجابة عند وقوع الخطر.
- الحالة: مفتوح، أو قيد المعالجة، أو مقبول، أو مغلق.

6.6 المراجعة والتقارير

- يُراجَع سجل المخاطر وفق الدورية المحددة لكل مستوى.
- يُرفع تقرير ربع سنوي بالمخاطر الحرجة والمرتفعة إلى الرئيس التنفيذي للإدارة التنفيذية للاتصالات وتقنية المعلومات.

7. الاستثناءات وطلبات الإعفاء

- يجوز للإدارة أو الوحدة التي يتعذر عليها الالتزام ببند من بنود هذه السياسة لأسباب تشغيلية موضوعية (مثل تأجيل معالجة خطر مرتفع لقيود في الميزانية مع ضوابط تعويضية) تقديم طلب استثناء رسمي عبر مكتب الخدمة.
- يتضمن الطلب: البند المطلوب الاستثناء منه، والمبرر، والمدة المطلوبة، والضوابط التعويضية المقترحة للحد من المخاطر.
- يُعتمد الاستثناء من الرئيس التنفيذي للإدارة التنفيذية للاتصالات وتقنية المعلومات، ويُوثَّق في سجل الاستثناءات، ويُراجَع عند انتهاء مدته.
- لا تُمنح استثناءات على المتطلبات الإلزامية الواردة في الأنظمة الوطنية، ومنها الضوابط الأساسية للأمن السيبراني ونظام حماية البيانات الشخصية.

8. الإنفاذ والامتثال

- يُعد الالتزام بهذه السياسة إلزاميًا على جميع الفئات المشمولة بنطاقها.
- تُلزم المشاريع والتغييرات التقنية الجديدة بتقييم مخاطرها قبل التنفيذ وفق هذه السياسة.
- تُحال المخالفات المتكررة أو الجسيمة إلى الرئيس التنفيذي للإدارة التنفيذية للاتصالات وتقنية المعلومات والإدارة المعنية لاتخاذ الإجراء المناسب وفق أنظمة الجامعة ولوائحها.
- تُراجَع هذه السياسة سنويًا على الأقل، أو عند حدوث تغييرات جوهرية في الأنظمة أو المتطلبات التنظيمية أو البيئة التقنية.

9. الأدوار والمسؤوليات

الجهة / الدور	المسؤولية
الإدارة التنفيذية للاتصالات وتقنية المعلومات	تطبيق إطار إدارة المخاطر، وإدارة سجل المخاطر، ومتابعة خطط المعالجة.
الرئيس التنفيذي للإدارة التنفيذية للاتصالات وتقنية المعلومات	قبول المخاطر المرتفعة، والاطلاع على التقارير الربع سنوية، واعتماد الاستثناءات.
رئيس الجامعة	قبول المخاطر الحرجة.
مالكو المخاطر	إدارة معالجة المخاطر المسندة إليهم والاستجابة عند وقوعها.
فريق الأمن السيبراني	تقييم المخاطر الأمنية، والفحوص الأمنية، ومراقبة التهديدات.
جميع منسوبي الإدارة	الإبلاغ عن المخاطر المحتملة والمشاركة في التقييمات.

10. السياسات ذات العلاقة

- سياسة إدارة التغيير في تقنية المعلومات (ICTD-06P)
- سياسة النسخ الاحتياطي والاستعادة (ICTD-08P)
- سياسة مركز البيانات وغرف الخوادم (ICTD-09P)
- سياسة الأمن السيبراني (ICTD-24P)

11. المصطلحات والتعريفات

تم تعريف مجموعة مشتركة من المصطلحات والتعريفات المستخدمة في سياسات ITCGA في وثيقة «التعريفات المشتركة لتقنية المعلومات» sd.sr.edu.sa

المصطلح	التعريف
الخطر	حدث محتمل قد يؤثر سلبًا على أصول الجامعة أو خدماتها.
الاحتمالية	مدى إمكانية وقوع الخطر.
الأثر	الضرر المحتمل الذي قد يسببه الخطر للجامعة.

المصطلح	التعريف
مالك الخطر	الشخص المسؤول عن إدارة الخطر ومعالجته.
سجل المخاطر	السجل الذي تُوثَّق فيه المخاطر وتقييمها ومعالجتها ومتابعتها.
الضوابط التعويضية	إجراءات بديلة تقلل الخطر عند تعذر تطبيق الضابط الأساسي.
مكتب الخدمة	خدمة استقبال الطلبات والإبلاغ عن الأعطال عبر الرابط sd.sr.edu.sa

12. تاريخ المراجعة

الإصدار	التاريخ	تم التعديل بواسطة	سبب التغيير	تمت المراجعة بواسطة
1	مارس 2017	الإدارة العامة للاتصالات وتقنية المعلومات	إصدار	الإدارة العامة للاتصالات وتقنية المعلومات
2	أكتوبر 2019	الإدارة العامة للاتصالات وتقنية المعلومات	مراجعة	الإدارة العامة للاتصالات وتقنية المعلومات
3	نوفمبر 2020	الإدارة العامة للاتصالات وتقنية المعلومات	مراجعة	الإدارة العامة للاتصالات وتقنية المعلومات
4	نوفمبر 2021	الإدارة العامة للاتصالات وتقنية المعلومات	مراجعة	الإدارة العامة للاتصالات وتقنية المعلومات
5	يونيو 2022	الإدارة العامة للاتصالات وتقنية المعلومات	مراجعة	الإدارة العامة للاتصالات وتقنية المعلومات
6	سبتمبر 2022	الإدارة العامة للاتصالات وتقنية المعلومات	مراجعة	الإدارة العامة للاتصالات وتقنية المعلومات
7	يناير 2023	الإدارة العامة للاتصالات وتقنية المعلومات	مراجعة	الإدارة العامة للاتصالات وتقنية المعلومات
8	مارس 2017	الإدارة العامة للاتصالات وتقنية المعلومات	مراجعة	الإدارة العامة للاتصالات وتقنية المعلومات
9	فبراير 2023	الإدارة العامة للاتصالات وتقنية المعلومات	مراجعة	الإدارة العامة للاتصالات وتقنية المعلومات
10	نوفمبر 2024	الإدارة العامة للاتصالات وتقنية المعلومات	مراجعة	الإدارة العامة للاتصالات وتقنية المعلومات
11	يناير 2025	الإدارة العامة للاتصالات وتقنية المعلومات	مراجعة	الإدارة العامة للاتصالات وتقنية المعلومات
12	أكتوبر 2026	الإدارة التنفيذية للاتصالات وتقنية المعلومات	مراجعة وإعادة هيكلة وفق القالب الموحد واستكمال الأقسام	الإدارة التنفيذية للاتصالات وتقنية المعلومات

13. اعتماد الوثيقة

إعداد	مراجعة	اعتماد	اعتماد
الإدارة التنفيذية للاتصالات وتقنية المعلومات	الإدارة التنفيذية للاتصالات وتقنية المعلومات	الرئيس التنفيذي للإدارة التنفيذية للاتصالات وتقنية المعلومات	رئيس الجامعة
التوقيع / التاريخ	التوقيع / التاريخ	التوقيع / التاريخ	التوقيع / التاريخ